



PCI BO 사이트 작업 보고



인사총무팀_홍성원 작업내용

로드밸런싱 작업

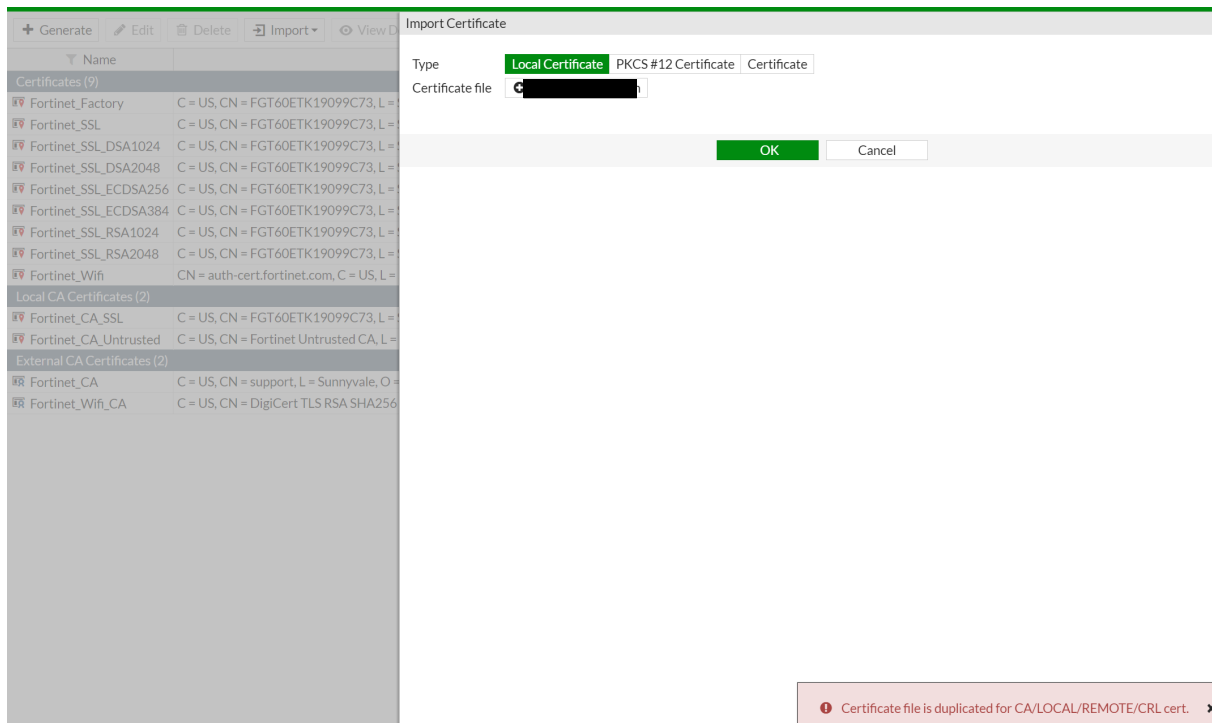
✓ 1단계: ~~SSL~~ 인증서 가져오기

1. Fortigate GUI에 접속:

- 웹 브라우저를 열고 Fortigate 관리 IP 주소로 이동합니다.
- 관리자 계정으로 로그인합니다.

2. SSL 인증서 가져오기:

- **System > Certificates**로 이동합니다.
- **Import > Local Certificate**를 클릭합니다.
- [REDACTED].io에 대한 인증서 파일을 선택하여 업로드합니다.
- 가져오기 후 인증서 상태가 **Valid**인지 확인합니다.



~~현재 SSL 인증서 Import시, 중복된 인증서로 취급됨. (기존에 등록해두었던 것으로 추정)~~

241007 - SSL 인증서 변환 후 import 완료, VIP SERVER 설정에서 SSL Offloading Mode를 Client ↔ Fortigate로 설정해줘야 정상적으로 동작됨

SSL Offloading을 ****"Client ↔ Fortigate mode"**로 설정한 이유는 **FortiGate가 SSL 트래픽을 처리하면서도 백엔드 서버에 대한 부담을 줄이고, SSL 처리에 필요한 자원 절감과 보안 관리의 효율성을 높이기 위함**

Full SSL Offloading 모드는 클라이언트 ssl세션 뿐 아니라 서버 ssl세션까지 관리하므로 보안성은 더 높지만 자원 소모와 성능부담이 크다.

✓ 2단계: 실제 서버(Real Server) 구성

1. 실제 서버 정의:

- **Policy & Objects > Virtual Servers > Real Servers**로 이동합니다.
- **Create New**를 클릭하여 새로운 실제 서버를 추가합니다.
 - **Name:** Real_Server_1
 - **Type:** [REDACTED]

- **IP Address:** [REDACTED]
- **Port:** [REDACTED] SSL 오프로딩으로 인해 서버로의 트래픽은 [REDACTED]니다)
- 두 번째 서버도 동일하게 추가합니다:
 - **Name:** Real_Server_2
 - **IP Address:** 1 [REDACTED]
 - **Port:** [REDACTED]

+ Create New Edit Delete Search						
Name	Type	Virtual Server IP	Load Balancing Method	Health Check	Real Servers	Interface
IPv4 Virtual Server						
VS_safe_payprotocol	HTTP	[REDACTED]	Static	HTTP_Health_Check	[REDACTED]	wan1

✓ 3단계: 헬스 체크 구성

1. 헬스 체크 모니터 생성:

- **Policy & Objects > Virtual Servers > Health Check**로 이동합니다.
- **Create New**를 클릭합니다.
 - **Name:** HTTP_Health_Check
 - **Type:** HTTP
 - **URL Path:** / (또는 특정 엔드포인트)
 - **HTTP Version:** HTTP/1.1
 - **Interval:** 5초
 - **Timeout:** 2초
 - **Retry:** 3회
- **OK**를 클릭하여 저장합니다.

Edit Health Check Monitor

Name: HTTP_Health_Check

Type: ☐ Ping ☐ TCP ☒ HTTP

Interval: 5 seconds

Timeout: 2 second(s)

Retry: 3 attempt(s)

Port: 80

URL: /

Matched content:

Max redirects: 0

OK Cancel

✓ 4단계: 가상 서버(Virtual Server) 생성

1. 가상 서버 생성:

- **Policy & Objects > Virtual Servers > Virtual Servers**로 이동합니다.
- **Create New**를 클릭합니다.
 - **Name:** VS_safe_payprotocol
 - **Type:** HTTPS
 - **Interface:** [redacted] 이 연결된 WAN 인터페이스 선택
 - **Virtual Server IP:** [redacted]
 - **Virtual Server Port:** [redacted]
 - **Load Balancing Method:** 원하는 방법 선택 (예: **Round Robin, Least Connections**)
 - **Enable SSL Offloading:** 체크
 - **Certificate:** 가져온 *. [redacted] 인증서 선택
 - **Real Servers:** Real_Server_1과 Real_Server_2 추가
 - **Health Check Monitor:** HTTP_Health_Check 선택
- **OK**를 클릭하여 저장합니다.

Name	Type	Virtual Server IP	Load Balancing Method	Health Check	Real Servers	Interface
IPv4 Virtual Server						
VS_safe_payprotocol	HTTP	[redacted]	Static	HTTP_Health_Check	[redacted]	wan1

✓ ~~5단계: 방화벽 정책 구성~~

1. 가상 서버로의 트래픽 허용:

- **Policy & Objects > IPv4 Policy**로 이동합니다.
- **Create New**를 클릭합니다.
 - **Name:** Allow_HTTPS_to_VS
 - **Incoming Interface:** WAN 인터페이스 (예: wan1)
 - **Outgoing Interface:** 내부 네트워크에 연결된 인터페이스 (예: lan)
 - **Source:** All 또는 필요한 경우 특정 소스 지정
 - **Destination:** Virtual Server – VS_safe_payprotocol 선택
 - **Service:** HTTPS
 - **Action:** Accept
 - **NAT:** 일반적으로 인바운드 트래픽에는 필요 없음
- **OK**를 클릭하여 저장합니다.

Edit Policy

Name ⓘ

Allow_HTTPS_to_VS

Incoming Interface

wan1

Outgoing Interface

NC_Site

Source

all

Destination

VS_safe_payprotocol

Schedule

always

Service

ALL

Action

☒ ACCEPT ☐ DENY

Firewall / Network Options

NAT

☐

Security Profiles

AntiVirus

☐

Web Filter

☐

DNS Filter

☐

Application Control

☐

SSL Inspection

☐

Logging Options

Log Allowed Traffic

☒

Security Events

All Sessions

Comments

Write a comment...

Enable this policy

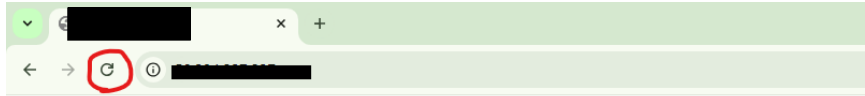
☒

OK

Cancel

테스트

1. 도메인에 검색, 새로고침 반복



사이트에 보안 연결할 수 없음

에서 잘못된 응답을 전송했습니다.

Windows 네트워크 진단 프로그램을 실행해 보세요.

ERR_SSL_PROTOCOL_ERROR

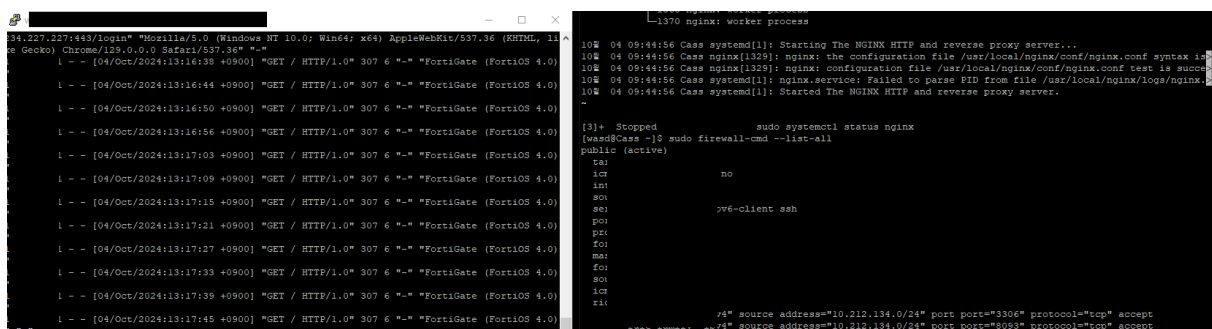
새로고침

2. https Allow 정책의 Byte 수 증가 확인

Allow_HTTPS_to_VS 방화벽 정책이 설정된 대로 [redacted] 으로 들어오는 HTTPS 트래픽을 허용하고 있다는 것을 의미. 이 정책이 클라이언트에서 서버로 가는 트래픽을 필터링하고 허용하고 있음을 나타냄

wan1 -> HC_Site	25	Allow_HTTPS_to_VS	all	VS_safe_payprotocol	always	ALL	ACCEPT	Disabled	All	267.21 KB
-----------------	----	-------------------	-----	---------------------	--------	-----	--------	----------	-----	-----------

3. 로그 파일 확인



- 현재 [redacted] 2 (테라) 에서는 로그가 정상적으로 잡히지만 [redacted] 3 (카스) PC에서는 조회되지 않는 상황.

- 로드밸런싱 정책 점검 or 카스 서버 방화벽 점검 필요함

🙄오류수정

카스 서버 80port 설정에 오류가 있었음 → 수정 완료

로드밸런싱 구현 완료/ 서버 로그 확인 완료

보안설정



허가받은 사용자만 해당 사이트에 접근할 수 있게 설정

현재 사용중인 VPN 터널 정책 유지, 웹서버 구축 완료 시 추가 작업 예정

- VPN그룹 사용자명 변경 예정
 - SafePayprotocol 그룹 생성 → 계정 생성 요청자들 그룹 등록완료
- 접근 로그 추적기능 설정 예정

웹인증 방식 채택 배경

배경

프로젝트의 주요 목표는 특정 서비스인 **safe.payprotocol.io**에 대한 접근을 **제어**하고, **보안성을 강화**하는 것이었습니다. 처음에는 **FortiGate의 VIP 설정**을 통해 외부에서 내부 서버로의 트래픽을 전달하고 접근을 제어하려 했으나, **SSL-VPN과 VIP 설정의 호환성 문제**로 인해 다른 방식을 검토하게 되었습니다.

VIP 및 내부 서버 IP 사용 시 발생한 문제

1. SSL-VPN 인터페이스와 VIP의 비호환성:

- FortiGate에서는 **ssl.root** 인터페이스가 **SSL-VPN**을 위해 사용되며, **VIP 설정을 통한 외부 트래픽 포워딩**과 호환되지 않습니다. 이는 **VPN 터널 내에서만 통신할 수 있는 특성**으로 인해 **VIP와 같은 외부 네트워크에서 내부로의 포트 포워딩**이 제한되기 때문입니다.
- VIP 설정은 주로 ****wan1***과 같은 외부 인터페이스에서 사용되지만, **SSL-VPN(ssl.root) 인터페이스에서는 이를 사용할 수 없었고**, 결과적으로 VIP 대신 다른 접근 방식을 검토할 필요가 생겼습니다.

2. 내부 서버 IP 직접 설정 문제:

- **VIP 대신 내부 서버 IP를 직접 설정**하여 SSL-VPN 사용자가 내부 자원에 접근하도록 시도했으나, 이 방식 역시 성공하지 못했습니다. FortiGate의 **SSL-VPN과 정책 설정**이 내부 서버 IP로도 제대로 라우팅되지 않는 문제가 있었습니다.
- **SSL-VPN 사용자가 직접 내부 서버 IP에 접근할 수 있도록 설정**했음에도 불구하고, FortiGate의 정책 및 라우팅 제한 사항으로 인해 **내부 자원 접근이 차단**되거나 불가능한 상황이 발생했습니다.

정적 라우팅 사용의 한계

1. 정적 라우팅이 다른 정책에 미치는 영향:

- 정적 라우팅을 통해 SSL-VPN 사용자가 내부 서버로 트래픽을 보낼 수 있도록 설정할 수 있지만, FortiGate 내에서 **다른 정책들에 영향을 미칠 위험**이 있었습니다.
- 특히, FortiGate의 네트워크 환경에서 **다른 서비스 및 정책이 이미 설정된 상태**였기 때문에, 정적 라우팅을 변경할 경우 예상치 못한 네트워크 충돌이나 접근 제어 문제가 발생할 가능성이 있었습니다.
- 정적 라우팅을 수정하는 대신, **다른 방식으로 특정 사이트에 대한 접근을 제한**하고 인증 절차를 도입하는 것이 더 안전한 선택으로 판단되었습니다.

웹 인증 방식 채택 이유

VIP 및 내부 서버 IP 설정이 실패하고, 정적 라우팅의 위험성이 존재하는 상황에서, **웹 인증 방식**이 최적의 대안으로 떠올랐습니다.

1. 보안 강화 및 사용자 제어:

- 웹 인증을 통해 사용자가 **ID와 비밀번호를 통해 인증**을 받도록 설정함으로써, **안전하게 접근을 통제**할 수 있었습니다. **비인증 사용자의 접근을 차단**하고, 인증된 사용자만 내부 자원에 접근할 수 있도록 했습니다.

2. FortiGate SSL-VPN의 웹 인증 방식:

- FortiGate의 **SSL-VPN 웹 모드**를 사용하면 **FortiClient를 설치하지 않아도** 사용자가 **브라우저만으로 인증**을 받을 수 있었습니다. 이는 사용자 편의성을 높이면서도 보안을 유지하는 데 적합했습니다.

3. 정적 라우팅 수정의 필요성 제거:

- 웹 인증 방식을 채택함으로써 **정적 라우팅을 변경할 필요가 없어졌고**, FortiGate 내의 다른 정책이나 네트워크에 영향을 미치지 않고도 **특정 사이트에 대한 접근을 통제**할 수 있었습니다.

4. 웹 인증을 통한 세밀한 접근 관리:

- 웹 인증 방식을 통해 **특정 사용자 그룹에 대한 접근 제어**가 가능해졌습니다. 이를 통해 **50명의 사용자가 매번 로그인하여 인증**을 받아야만 [REDACTED]에 접근할 수 있게 되었습니다.
- 사용자는 SSL-VPN에 접속한 후 **인증 페이지**로 리디렉션되고, 인증이 완료되면 원래 사이트로 다시 돌아가 접근할 수 있도록 구성되었습니다.

사용한 명령어 및 기술 정보

1. SSL-VPN 포털 생성 및 설정

- **SSL-VPN 포털 설정**은 SSL-VPN 사용자들이 브라우저를 통해 인증할 수 있는 포털을 생성하는 과정입니다.
- 사용된 명령어:

```
bash
코드 복사
config vpn ssl settings
set port [REDACTED] # SSL-VPN이 [REDACTED]을 사용하도록 설정
end
```

2. 사용자 그룹 및 정책 설정

- 특정 사용자 그룹을 생성하고, 웹 인증이 필요한 사용자를 해당 그룹에 추가했습니다.
- 방화벽 정책에 웹 인증을 추가하여, **SafePayprotocol 사이트에 대한 접근을 제한**했습니다.
- 사용된 명령어:

```
bash
코드 복사
config firewall policy
edit 24 # SafePayprotocol에 대한 정책 번호
set auth-redirect-addr [REDACTED] " # 웹 인증 후
리디렉션 설정
set groups "[REDACTED]" # 인증 그룹 설정
end
```

3. 세션 종료 및 인증 관리

- SSL-VPN 사용자들이 다시 인증을 요구받도록 **세션을 수동으로 종료**하는 방법도 활용했습니다.
- 사용된 명령어:

```
bash
코드 복사
diagnose vpn sslvpn disconnect <사용자 IP> # 특정 사용자의
SSL-VPN 세션 종료
```

4. 로그 및 디버그 확인

- FortiGate에서 인증과 관련된 **로그 및 디버깅 정보**를 확인하여 문제를 분석했습니다.
- 사용된 명령어:

```
bash
코드 복사
diagnose debug application sslvpn -1 # SSL-VPN 디버그 로
그 활성화
diagnose debug enable
```

결론 및 효과

이번 프로젝트에서 **웹 인증 방식**을 채택한 이유는, **VIP 설정의 제한, 내부 서버 IP 직접 설정 실패, 그리고 정적 라우팅 수정의 위험성** 때문입니다. 웹 인증 방식은 **보안성 강화, 편리한 사용자 인증 절차, 그리고 기존 정책에 영향을 미치지 않는 안전한 방식**으로 작동하였습니다.

이를 통해 **사용자 접근을 통제**하고, **내부 자원 보호와 정책 관리의 일관성**을 유지할 수 있었습니다. 향후에는 **정기적인 보안 점검**을 통해 웹 인증 정책을 최적화하고, 필요에 따라 추가적인 보안 조치를 도입할 예정입니다.